

IBM · ICA · SAP AUTHORIZATION INTELLIGENCE

UM_AUTHORITY-CHECK-ANALYZER

Implementation Strategy & User Guide — v1.0

Prepared By

Utsav Mukherjee

Document Version

v1.0 — August 2026

Classification

Internal — IBM / ICA

Platform

GitHub Pages CDN (Always Online)

PERMANENT PUBLIC URL
<https://ica-bob.github.io/um-authority-check-analyzer/>

SOURCE REPOSITORY
<https://github.com/ica-bob/um-authority-check-analyzer>

TABLE OF CONTENTS

1. Executive Summary	2
2. Tool Overview & Purpose	2
3. System Architecture	3
4. Data Flow Diagram	4
5. Feature Infographic	5
6. Analysis Modules — Detail	6
7. Implementation Strategy	7
8. Step-by-Step User Guide	8
9. Security & Governance Controls	9
10. Repository Structure	10
11. Deployment Architecture	11
12. Authorization Objects Reference	12

01 EXECUTIVE SUMMARY

The **UM_Authority-Check-Analyzer** is a governed SAP Authorization Diagnostic Intelligence tool developed by Utsav Mukherjee under the IBM ICA (Intelligent Code Assistant) program. It provides SAP security teams with a fast, interactive, browser-based interface to detect, classify, and remediate authorization defects across ABAP programs, SU24 transaction proposals, and OData/Fiori service layers.

The tool operates entirely in the browser — no data is sent to any server, no SAP system connection is established, and no changes are made automatically. All findings are diagnostic only and require human approval from SAP Security before any correction is applied.

CURRENTLY LIVE

Hosted permanently on GitHub Pages CDN. Available 24×7 globally. No login, no installation, no laptop dependency.

URL:

[HTTPS://ICA-BOB.GITHUB.IO/UM-AUTHORITY-CHECK-ANALYZER/](https://ica-bob.github.io/um-authority-check-analyzer/)

02 TOOL OVERVIEW & PURPOSE

What It Does

The tool guides a SAP security analyst or developer through a structured, conversational diagnostic workflow. The analyst provides context (SAP system, release, transaction, business action, evidence), and the tool runs one or more of three specialized analyzers to produce structured findings with severity ratings, evidence, impact assessment, and code-level remediation guidance.

- Why It Was Built**
- SAP authorization defects are frequently missed during code reviews due to the complexity of AUTHORITY-CHECK patterns
 - SU24 proposal gaps cause role generation failures that are hard to diagnose without specialized knowledge
 - OData/Fiori services are often deployed without DPC_EXT authorization checks, creating critical exposure
 - IBM ICA and IBM Bob needed a governed, audit-trail-enabled interface aligned with MCP Gateway standards

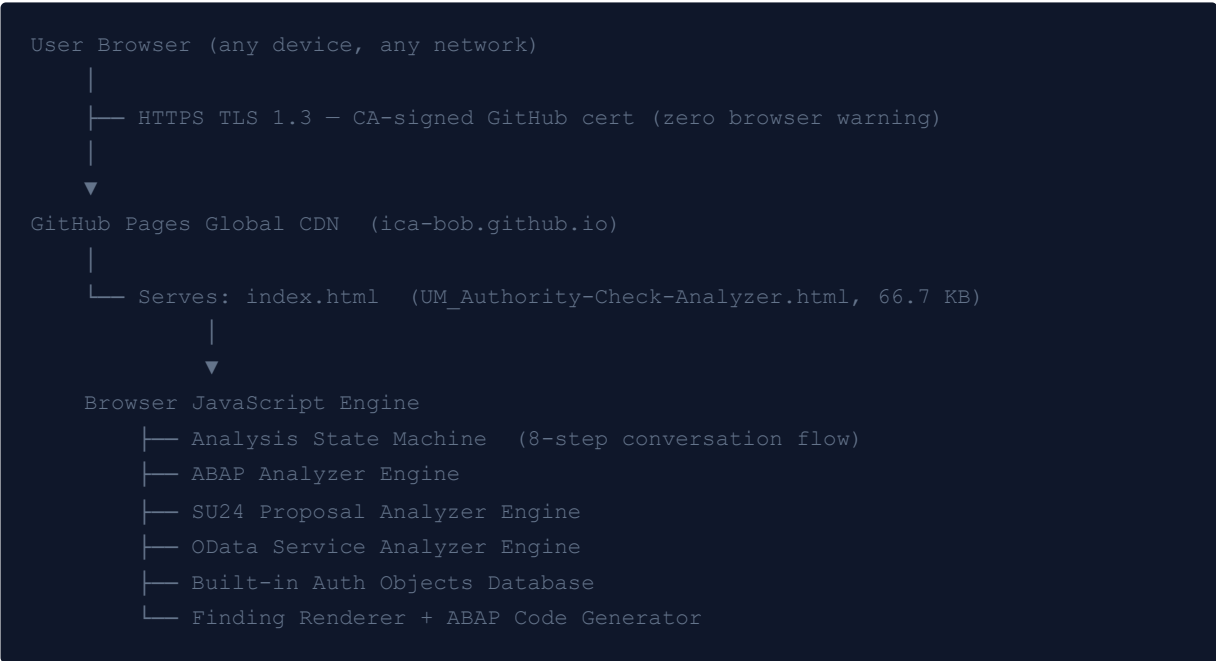
Key Characteristics

Attribute	Detail
Type	Static single-page application — pure HTML/CSS/JavaScript
Backend	None — all logic runs client-side in the browser
Data persistence	None — session-only, no cookies, no localStorage
Network calls during analysis	Zero — no external API calls

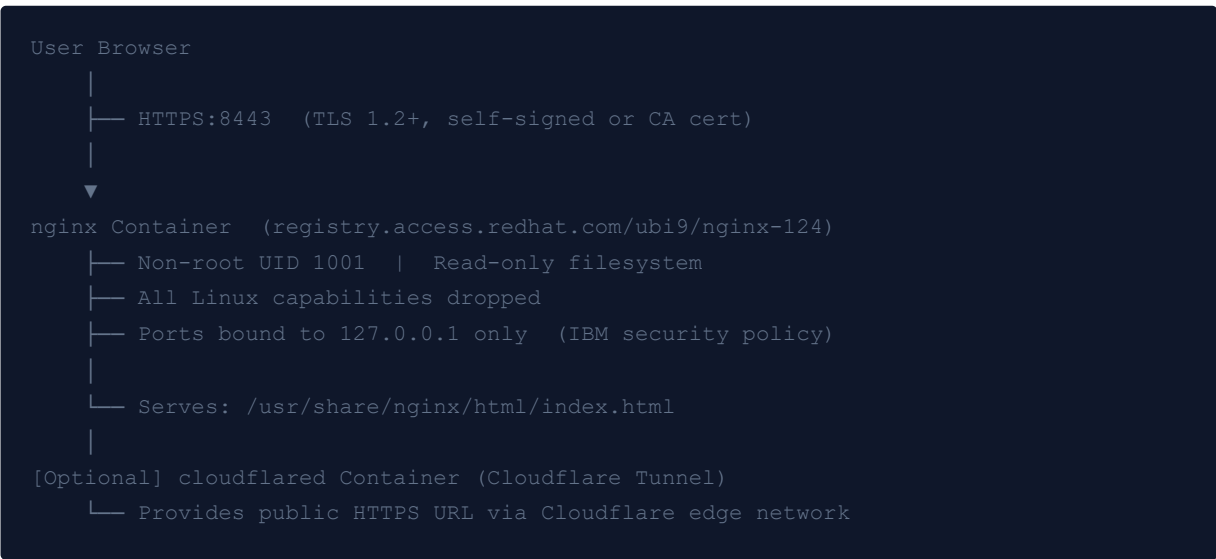
SAP connectivity	None — descriptive input, no RFC/BAPI calls
File size	66.7 KB — single self-contained HTML file
Hosting	GitHub Pages CDN — globally available, 99.9% uptime

03 SYSTEM ARCHITECTURE

Production Architecture (GitHub Pages — Active)



Enterprise / Local Architecture (Docker)

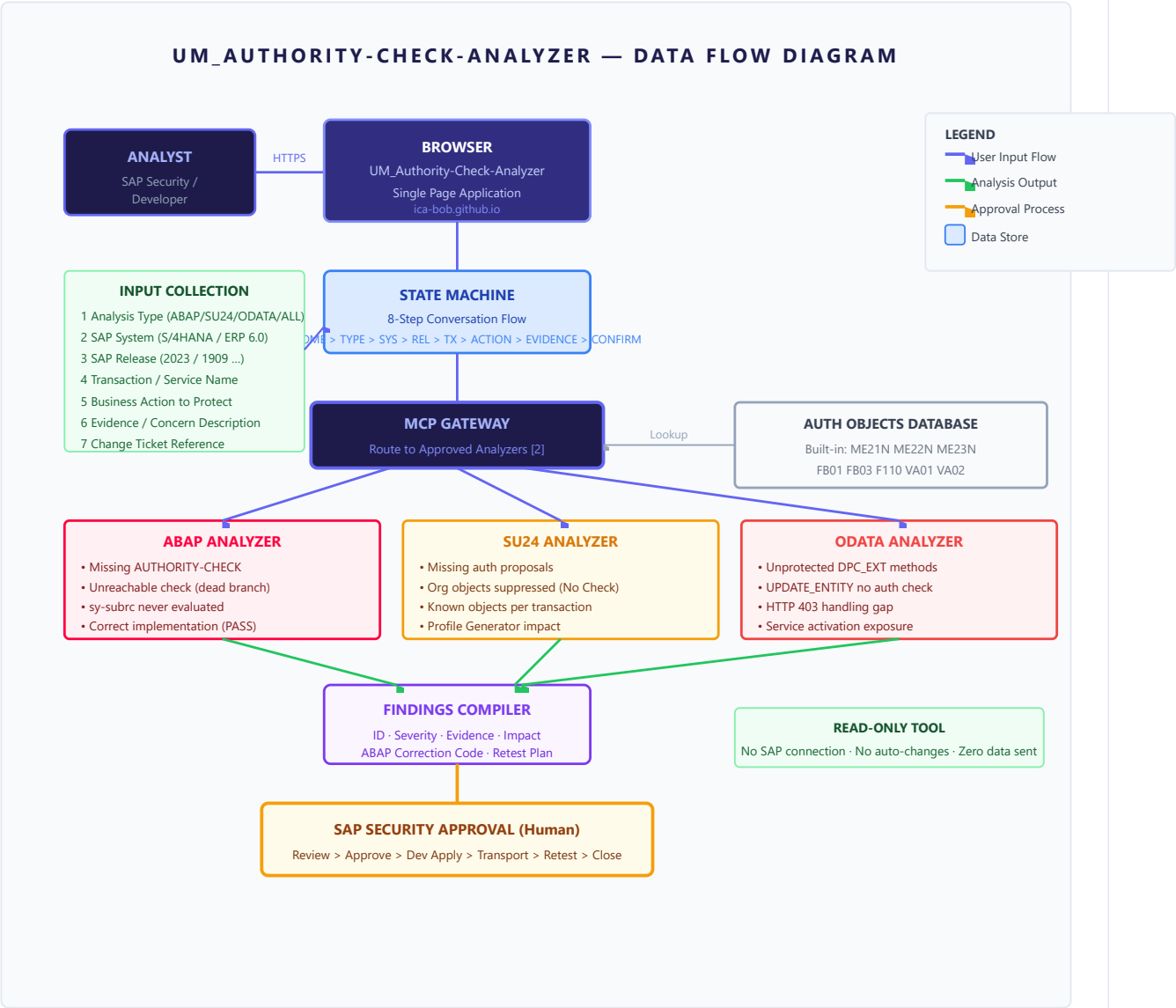


ARCHITECTURE DECISION

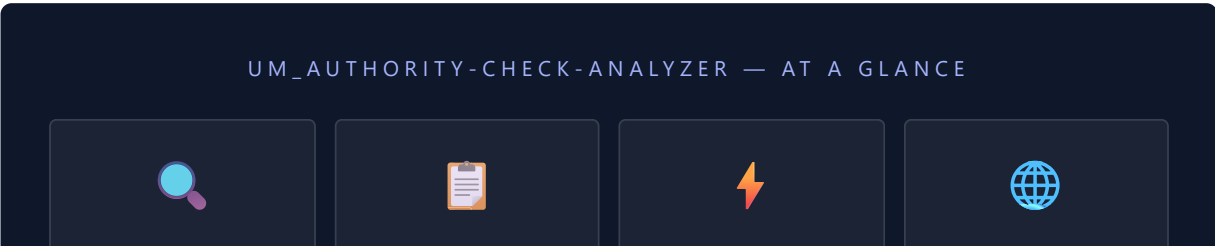
GitHub Pages is the recommended and active deployment. The Docker stack is maintained in the repository for enterprise / intranet deployments where internet access is restricted or a corporate reverse

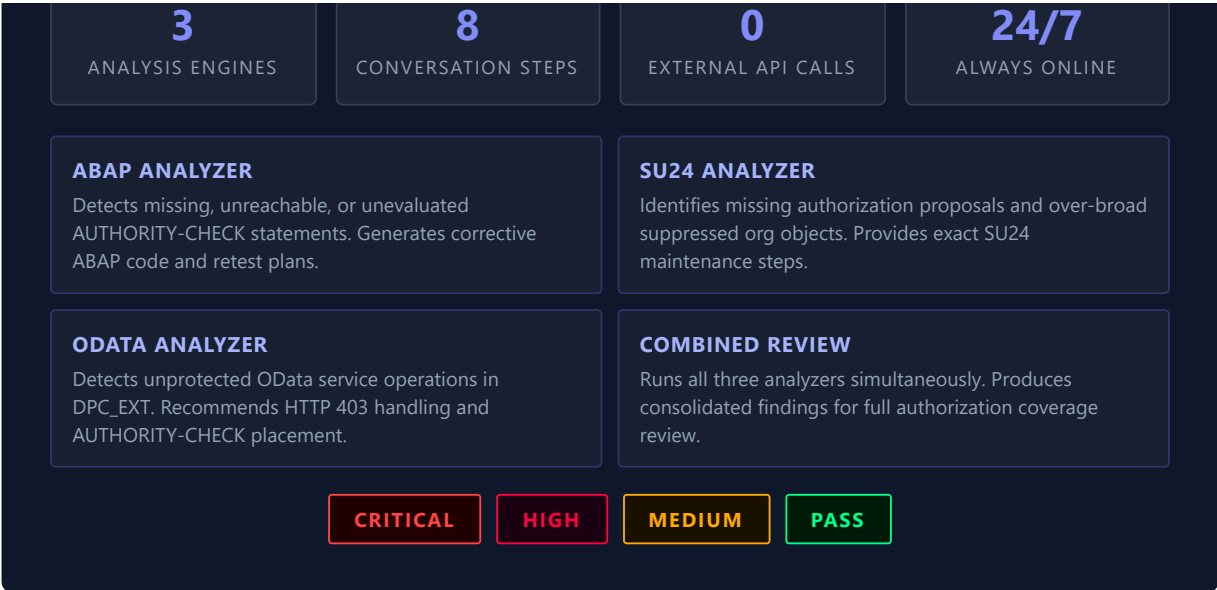
proxy is required.

04 DATA FLOW DIAGRAM



05 FEATURE INFOGRAPHIC





06 ANALYSIS MODULES — DETAIL

6.1 ABAP Authority-Check Analyzer

Finding Type	Severity	Evidence Keywords	Description
MISSING	HIGH	default	No AUTHORITY-CHECK before sensitive operation. Generates full corrective ABAP code using known objects for the transaction.
UNREACHABLE	HIGH	unreachable, branch	AUTHORITY-CHECK exists but is in a dead code branch — does not protect the actual execution path.
NOT EVALUATED	HIGH	sy-subrc, not evaluated, ignored	Check executes but sy-subrc is never tested. Operation proceeds regardless of authorization result.
PASS	PASS	correct, pass, working	Check correctly placed, evaluated, and matched to declared business action.

6.2 SU24 Proposal Analyzer

Finding Type	Severity	Evidence Keywords	Description
MISSING PROPOSAL	HIGH	default	Expected authorization objects absent from SU24 transaction proposal. Provides exact objects and fields to add per transaction.
TOO BROAD	MEDIUM	broad, no check, suppress	Org restriction objects set to "No Check" — Profile Generator suppresses them, users get cross-org access.

6.3 OData Service Analyzer

Finding Type	Severity	Description
UNPROTECTED OPERATION	CRITICAL	UPDATE_ENTITY or change operations in DPC_EXT without AUTHORITY-CHECK. Any activated-service user can modify business data.

6.4 Finding Card Fields

Field	Description
Finding ID	Unique traceable ID — e.g. AUTH-2026-45812 , SU24-2026-31044 , ODATA-2026-72301
Checker	Which analyzer produced the finding
Severity	CRITICAL / HIGH / MEDIUM / PASS
Transaction	SAP transaction or service name entered by analyst
Evidence	Technical detail of what was detected
Impact	Business and security impact of the defect
Confidence	HIGH / MEDIUM-HIGH
Recommended Correction	Exact ABAP code or SU24 steps to remediate
Retest Plan	Positive and negative test cases to verify fix

07 IMPLEMENTATION STRATEGY

Phase 1 — Immediate Adoption (Complete)

STATUS: LIVE

Tool deployed at <https://ica-bob.github.io/um-authority-check-analyzer/> and available to all IBM/ICA team members globally. No setup required for end users.

- GitHub Pages deployment under ica-bob organisation
- Permanent URL — never changes, no laptop dependency
- CA-signed TLS — no browser security warning

Phase 2 — Team Enablement

- Distribute this document to SAP Security, SAP Development, and IBM ICA teams
- Conduct a 30-minute walkthrough session using the Combined Review mode
- Establish a process: all ABAP authorization reviews use the tool before transport approval
- Define a naming convention linking tool Finding IDs to ServiceNow/JIRA tickets

Phase 3 — Process Integration

- Add the tool URL to the SAP Security team's standard operating procedures

- Include finding card output as mandatory attachment in SAP change requests for authorization objects
- Integrate with the existing Change Advisory Board (CAB) review process

Phase 4 — Enhancement Roadmap

Enhancement	Priority	Description
Expand AUTH_OBJECTS database	HIGH	Add MM, SD, FI, HR transaction authorization object mappings
PDF export of findings	MEDIUM	One-click finding card export for audit trail
Role impact checker	MEDIUM	Cross-reference findings with common role patterns
Fiori launchpad integration	LOW	Embed as Fiori tile within SAP landscape

08 STEP-BY-STEP USER GUIDE

OPEN IN ANY BROWSER

<https://ica-bob.github.io/um-authority-check-analyzer/>
No login · No installation · No VPN required

Quick Start Buttons

Button	Activates	Use When
ABAP CHECK	ABAP Analyzer	Reviewing ABAP program for missing/weak AUTHORITY-CHECK
SU24 PROPOSAL	SU24 Analyzer	Checking transaction authorization proposals in SU24
ODATA SERVICE	OData Analyzer	Reviewing Fiori/OData service DPC_EXT authorization
COMBINED REVIEW	All three	Full authorization coverage review of a transaction

Full Workflow — 8 Steps

- 1

Select Analysis Type

Type `check` or click a quick start button. Select ABAP, SU24, ODATA, or COMBINED.
- 2

Enter SAP System

Type the system: `S/4HANA` , `S/4HANA Private Edition` , or `ERP 6.0 EhP8` .
- 3

Enter SAP Release

Type the release: 2023 , 2022 , 1909 , 1809 etc.

4

Enter Transaction / Service

Type a SAP transaction code (ME22N , FB01 , VA01) or OData service name (ZVENDOR_SRV).
Known authorization objects are displayed automatically for recognised transactions.

5

Describe the Business Action

E.g. Change purchase order with purchasing org restriction or Post FI document with company code control .

6

Describe Evidence / Concern

Examples: Program calls CHANGE_DOCUMENT without AUTHORITY-CHECK · M_BEST_EKO missing from proposal · sy-subrc is not evaluated after the check · UPDATE_ENTITY has no authorization check in DPC_EXT

PRIVACY PROTOCOL ACTIVE
Passwords, tokens, secrets, and email addresses in evidence are automatically masked before processing.

7

Enter Change Ticket

Enter your ServiceNow / JIRA / SAP change ticket reference (e.g. CHG-2026-00123). Type skip if not available.

8

Review & Confirm

A confirmation summary is shown with all entered details. Click **PROCEED** to run analysis, **MODIFY** to change any field, or **CANCEL** to discard.

After Analysis — Next Steps

- 1. Route findings to SAP Security for review and approval
- 2. SAP Development applies approved corrections
- 3. Changes follow the normal SAP transport process
- 4. Retest using positive and negative scenarios from the finding card
- 5. Close the finding with the approved change ticket reference

HUMAN APPROVAL MANDATORY
ALL findings are diagnostic and read-only. The tool NEVER modifies any SAP system automatically. Every correction MUST be reviewed and approved by SAP Security before being applied.

Commands Reference

Command	Action
---------	--------

<code>check</code> / <code>analyze</code> / <code>inspect</code>	Start a new analysis session
<code>help</code>	Show available commands and analyzer descriptions
<code>reset</code>	Clear all inputs and restart from welcome screen
<code>skip</code>	Skip the change ticket field
<code>another</code> / <code>new</code>	Start a new analysis after completion

09 SECURITY & GOVERNANCE CONTROLS

Control	Implementation	Standard
TLS	GitHub Pages: TLS 1.3, CA-signed cert. Docker: TLS 1.2+ minimum, strong cipher suites (AES-256-GCM, ECDHE)	IBM Security \$5
No secrets in code	Zero hardcoded credentials, tokens, or passwords anywhere in the codebase	IBM Security \$4
Container security	Non-root UID 1001, all capabilities dropped, read-only filesystem, localhost binding only	IBM Security \$2
Base image	registry.access.redhat.com/ubi9/nginx-124 — Red Hat public UBI mirror	IBM Security \$2
Input sanitisation	All user input HTML-escaped before rendering; sensitive data auto-masked	IBM Security \$9
No data exfiltration	Zero network calls during analysis; no analytics, no tracking, no telemetry	IBM Security \$8
CSP headers	default-src 'self'; frame-ancestors 'none'; base-uri 'self' (Docker mode)	OWASP
HSTS	max-age=31536000; includeSubDomains (Docker mode)	IBM Security \$3
Human approval gate	Every finding card includes mandatory approval warning. Tool is read-only by design.	ICA Governance [2]

Automatic Data Masking

The tool masks the following patterns in user evidence input before any processing:

Pattern	Masked As
Passwords (<code>password: xxx</code>)	<code>password: [MASKED]</code>
Tokens / Bearer tokens	<code>token: [MASKED]</code> / <code>Bearer [MASKED]</code>
Secrets (<code>secret: xxx</code>)	<code>secret: [MASKED]</code>
Email addresses	<code>[EMAIL-MASKED]</code>

10 REPOSITORY STRUCTURE

Item	Value
GitHub Organisation	ica-bob — https://github.com/ica-bob
Repository Name	um-authority-check-analyzer
Full Repo URL	https://github.com/ica-bob/um-authority-check-analyzer
Default Branch	main
Pages Source	main branch, root /
Live URL	https://ica-bob.github.io/um-authority-check-analyzer/
Visibility	Public

File Structure

```
um-authority-check-analyzer/
|
├─ index.html                ← Application (66.7 KB, self-contained)
├─ README.md                 ← Permanent URL + quick-start guide
|
├─ Dockerfile                ← Container build (Red Hat UBI nginx-124)
├─ docker-compose.yml        ← Orchestration (app + cloudflared tunnel)
|
├─ nginx/
|   └─ nginx.conf             ← HTTPS server config (TLS 1.2+, security headers)
|
├─ scripts/
|   ├── generate-certs.sh      ← TLS cert generator (Linux / macOS)
|   ├── generate-certs.ps1     ← TLS cert generator (Windows)
|   ├── start-on-boot.ps1      ← Auto-start on login (Docker mode)
|   ├── register-startup-task.ps1 ← Register Windows scheduled task
|   └─ get-url.ps1            ← Show current Cloudflare tunnel URL
|
├─ certs/                    ← Runtime TLS certs (git-ignored)
|   ├── server.crt
|   └─ server.key
|
└─ .vscode/
    └─ launch.json            ← VS Code debug config (https://localhost:8443)
```

Updating the Application

```
# Via GitHub web UI (recommended — no git needed)
1. Go to https://github.com/ica-bob/um-authority-check-analyzer
2. Click index.html → Edit (pencil icon)
3. Paste updated content → Commit
4. GitHub Pages auto-redeploys in ~60 seconds
```

```
# Via git CLI
git clone https://github.com/ica-bob/um-authority-check-analyzer
cp UM_Authority-Check-Analyzer.html index.html
git add index.html
git commit -m "Update app vX.X"
git push
```

11 DEPLOYMENT ARCHITECTURE — ALL MODES

Mode	URL	Status	Requires	Best For
GitHub Pages	ica-bob.github.io/...	ACTIVE	Nothing — always online	All users globally — recommended
Docker Local	https://localhost:8443	Available	Docker Desktop + WSL 2	Local dev, offline use
Docker + Cloudflare Tunnel	*.trycloudflare.com	Ephemeral	Docker + internet access	Temporary sharing
Corporate Reverse Proxy	Custom internal URL	Configurable	Load balancer → Docker	Air-gapped enterprise

Docker Prerequisites

Prerequisite	Min Version	Notes
Windows 10/11	Build 19041+	WSL 2 support required
WSL 2	Any	Enable: <code>wsl --install --no-distribution</code> (needs reboot)
Docker Desktop	v24.x	WSL 2 backend; enable AutoStart in Docker Desktop settings
OpenSSL	Any recent	Included with Git for Windows

Docker Quick Start (Windows PowerShell)

```
# 1. Generate TLS certificates
.\scripts\generate-certs.ps1

# 2. Build and start (app + cloudflared tunnel)
docker compose up -d --build

# 3. Open locally
Start-Process "https://localhost:8443"

# 4. Get current public tunnel URL
.\scripts\get-url.ps1

# Useful commands
docker compose logs -f # View live logs
```

```
docker compose down      # Stop all containers
docker ps                # Check health status
```

12 AUTHORIZATION OBJECTS REFERENCE

The following transactions have built-in authorization object mappings. The tool automatically displays these when the transaction is entered, and uses them to generate precise finding cards and corrective ABAP code.

Transaction	Module	Authorization Objects	Activity
ME21N	MM — Purchasing	M_BEST_BSA, M_BEST_EKO, M_BEST_EKG, M_BEST_WRK	01 Create
ME22N	MM — Purchasing	M_BEST_BSA, M_BEST_EKO, M_BEST_EKG, M_BEST_WRK	02 Change
ME23N	MM — Purchasing	M_BEST_BSA, M_BEST_EKO	03 Display
FB01	FI — Accounting	F_BKPF_BUK, F_BKPF_KOA	01 Post
FB03	FI — Accounting	F_BKPF_BUK	03 Display
F110	FI — Payment Run	F_REGU_BUK, F_REGU_KOA	02 Change
VA01	SD — Sales	V_VBAK_AAT, V_VBAK_VKO	01 Create
VA02	SD — Sales	V_VBAK_AAT, V_VBAK_VKO	02 Change

EXTENDING THE DATABASE

Additional transactions can be added to the `AUTH_OBJECTS` constant in `index.html`. Edit the file via the GitHub web UI at github.com/ica-bob/um-authority-check-analyzer or submit a pull request.